

KIIRA MOTORS CORPORATION

HEALTH AND WELLNESS MANAGEMENT SYSTEM

ARCHITECTURE DOCUMENT

Field	Detail
Document name	Architecture document
Reference number	KMC.DQHSE.08/26-SP002
Document description	Technical architecture of the Health and Wellness Management System covering service topology, data ownership, identity, deployment and the decisions behind them
Prepared by	Akanga Andrew, Software Engineering Intern, Department of Quality, Health, Safety and Environment
Issue date	21/08/2026
Version	003
Classification	Internal, Restricted to KMC ICT and the Department of Quality, Health, Safety and Environment

Table of Contents

1 Introduction.....	0
1.1 Purpose.....	0
1.2 Guiding constraints.....	0
1.3 Technology.....	0
2 Service topology.....	0
2.1 Overview.....	0
2.2 Why not a single application.....	0
2.3 Communication.....	0
2.4 Clinical event boundary.....	0
3 Identity and session.....	0
3.1 The backend for frontend pattern.....	0
3.2 Roles.....	0
3.3 Account administration.....	0
3.4 Branding at sign-in and after sign-in.....	0
4 Data.....	0
4.1 Ownership rules.....	0
4.2 The clinical schema.....	0
4.3 Snapshots on forms.....	0
4.4 Effective-dated reference data and frozen evaluations.....	0
5 Deployment.....	0
5.1 Environments.....	0
5.2 Production Considerations.....	0
5.3 Observability.....	0
6 Maintainability.....	0
6.1 Known limitations.....	0
7 Handover.....	0

List of Figures

Figure 2.1: Service topology and request path.....	0
Figure 5.1: Separation Between User Testing and Production.....	0

List of Tables

Table 1.1: Technology choices and their reasons.....	0
Table 2.1: Six application services and what each owns.....	0
Table 3.1: Roles as held in the identity provider.....	0
Table 4.1: Data ownership rules.....	0
Table 5.1: Deployment constraints for production.....	0
Table 6.1: Measures that keep the topology maintainable.....	0
Table 6.2: Known limitations and their consequences.....	0
Table 7.1: Position at handover.....	0
Table 7.2: Architecture document sign-off.....	0

1 Introduction

1.1 Purpose

This document describes how the Health and Wellness Management System is built. It is written for KMC ICT, who will host the system and later maintain it, and for whoever inherits the code. It records not only what the structure is but why it was chosen, so that a future maintainer can tell a deliberate decision from an accident.

1.2 Guiding constraints

Four constraints shaped the architecture more than any preference did.

- Clinical data is special personal data under the Data Protection and Privacy Act, 2019, and the separation protecting it must be structural rather than procedural.
- Microservices are the architectural standard of the Corporation, following the precedent set by the Velo system.
- KMC ICT works in Go, so the backend is written in Go.
- The system was built by one intern whose attachment is ending, so operational complexity that a small team cannot carry is itself a defect.

1.3 Technology

Table 1.1: Technology choices and their reasons

S/N	Layer	Choice	Reason
1	Backend	Go with the chi router	Matches the standard KMC ICT works in. Single binary deployment suits on premise hosting
2	Persistence	PostgreSQL 16	Mature, well understood, and supports the separation the clinical context requires
3	Identity	Keycloak	Provides password policy, lockout, multi factor and later corporate single sign on without application code
4	Interface	React with TypeScript	Carries forward the direction reviewed in the prototype without treating that review as approval of every detail
5	Observability	Prometheus and Grafana	Operational monitoring for ICT, separate from the divisional dashboard
6	Local environment	Docker Compose	One command brings the whole system up on a laptop
7	Deployment target	Kubernetes manifests for k3s	Defines all six application services, the web origin, Keycloak and two PostgreSQL instances while the final ICT hosting choice remains open

2 Service topology

2.1 Overview

The system has six Go services behind one gateway route. Gateway, identity, clinical, admin, occupational and metrics are the application service set. The web origin and Keycloak are deployed

separately, but they are edge and identity infrastructure rather than additional business contexts. Each stateful service owns its database and exposes data only through its interface.

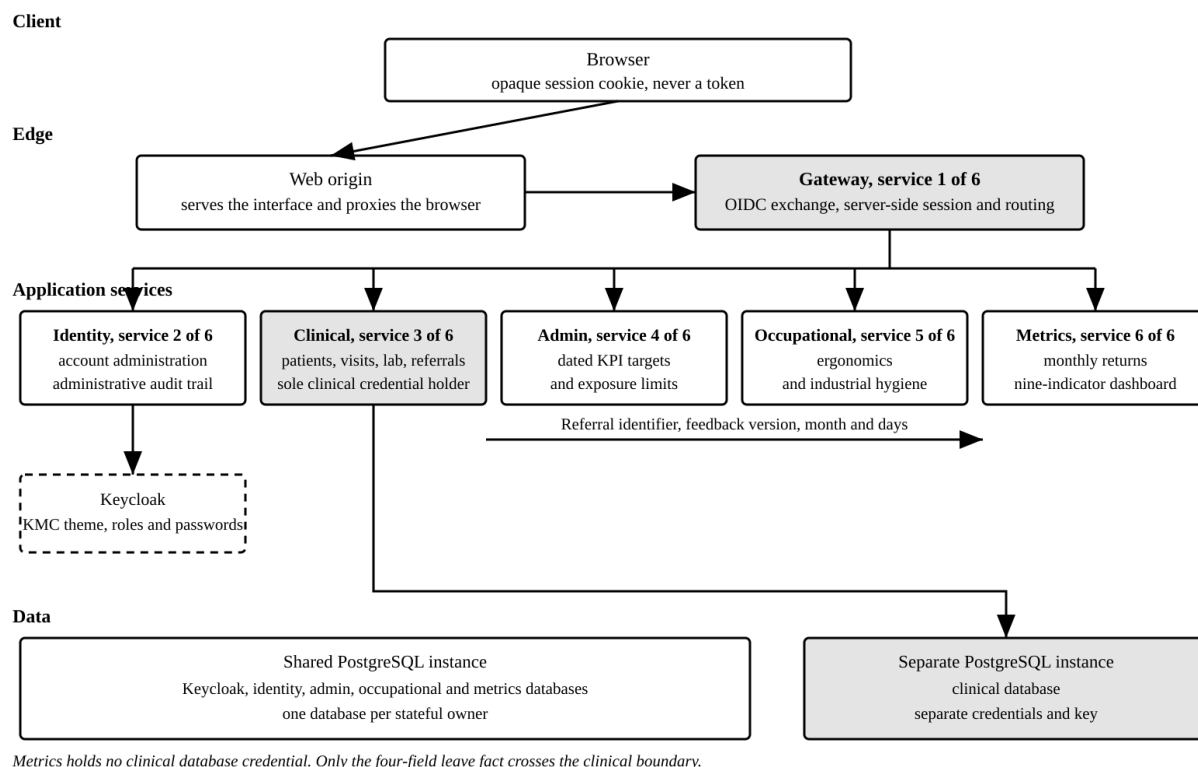


Figure 2.1: Service topology and request path

The clinical service shown in Figure 2.1 is the only workload issued a credential for the clinical database. That is not a deployment preference. It is the mechanism that makes the access rule structural, because a defect in another service cannot read a patient record when it holds nothing with which to try.

Table 2.1: Six application services and what each owns

S/N	Service	Owens	Special conditions
1	Gateway	Sign-in exchange, server-side session and routing	Holds no business data. The browser receives an opaque cookie rather than a token
2	Identity	Account administration and the administrative audit trail	Acts on Keycloak through its own service account, never the user token
3	Clinical	Patients, visits, laboratory requisitions, referrals and the leave outbox	Separate database instance and the only holder of its credentials
4	Admin	Effective-dated KPI targets and industrial hygiene limits	Supersedes a value by closing its row and opening a dated replacement
5	Occupational	Ergonomic assessments, corrective actions, hygiene monitoring events and readings	Holds no clinical content. A reading is a fact about a place
6	Metrics	Monthly returns, kept corrections, KPI computation and the dashboard	Holds no clinical database credential of any kind

The web deployment serves the signed-in interface and proxies the browser to the gateway. Keycloak supplies identity and the KMC login theme. They remain separate deployables so each can be operated and upgraded for its own purpose, but neither owns divisional records.

2.2 Why not a single application

An earlier draft of this architecture chose a modular monolith. The reasoning was a small user population, no independently scaling workload and a single maintainer, and on those grounds it was correct.

That decision was superseded for two reasons. The Corporation stated microservices as its standard, and alignment with that standard is a precondition of ICT accepting the system. More importantly, the split strengthens the property that matters most here. Under a single application the rule that only the clinical context holds clinical credentials was enforced by code review, because every context ran in one process with one configuration. Under this arrangement it is enforced by deployment.

The cost is real and is stated plainly. There are more moving parts to run than a single application would require, and that cost lands on whoever maintains the system after handover. Section 6 sets out the specific measures that hold it down.

2.3 Communication

Services communicate over HTTP with JSON. The gateway attaches a bearer token to every proxied call, and each service validates that token independently rather than trusting the gateway to have done so.

One communication rule is not negotiable. No service other than the clinical service reads a clinical record. Where another context requires a clinical contribution it receives an agreed non-identifying fact, never the record from which it came. This is why metrics can compute absenteeism while holding no clinical credential.

2.4 Clinical event boundary

When facility feedback records recommended sick leave, the clinical service writes the feedback and a leave contribution to `referral_leave_outbox` in one database transaction. Delivery can then retry without making the clinical save depend on metrics availability, and a successful clinical save cannot lose its contribution between two separate writes.

The publisher sends four fields to the internal metrics route: referral identifier, feedback version, reporting month and days. It sends no patient identifier, name, diagnosis, treatment or free text. Contract tests in both clinical and metrics inspect their migration column sets and fail the ordinary build if either side widens, because metrics has no clinical credential and must not become a second clinical store by gradual schema change.

Delivery is direct HTTP and at least once. Metrics is idempotent by referral identifier and feedback version, and retains the highest version as active, so a retry or an out-of-order correction changes the total once. Authentication currently uses a shared secret on an internal route rather than a scoped OIDC service account. That is a production weakness recorded at DEC-034, not a property this architecture treats as complete.

3 Identity and session

3.1 The backend for frontend pattern

The browser never holds a token. The gateway completes the sign in exchange with Keycloak, keeps the resulting tokens in server side session state, and returns to the browser an opaque session identifier in a cookie marked HttpOnly, Secure and SameSite.

This is the single most consequential decision in the identity design. In a system that holds health data, a token readable by any script on the page is not acceptable, and that risk is what the gateway exists to remove. A consequence worth stating is that the browser cannot call a service directly, so every authenticated call passes through one place where it can be inspected.

3.2 Roles

Roles are held in Keycloak and carried on the access token. The interface reads them to decide what to render, and every service checks them again to decide what to permit. The interface hiding a control is a courtesy. Refusing the request is the control.

Table 3.1: Roles as held in the identity provider

S/N	Role	Purpose	Clinical scope
1	hwms-officer	Health and Wellness Officer, the clinical role	Yes, and it is the only role that carries it
2	hwms-manager	Read only operations, plus account administration	No
3	hwms-director	Read only executive summaries	No

Roles are read from the access token rather than the identity token. Keycloak places realm roles on the access token and by default leaves them off the identity token entirely, so reading them from the identity token yields an empty set and signs a user in with no role and no navigation. That failure occurred once during build and is now covered by an automated test. Taking roles from the access token also keeps the gateway view of a caller identical to what the services enforce on, since that is the token forwarded to them.

3.3 Account administration

The manager creates officer and director accounts through the identity service. The manager token is never used to administer the identity provider. The service authorises the manager and then acts through its own service account, so a stolen manager token cannot create accounts directly.

The manager cannot grant the manager role. Account administration expands only by a decision taken outside that screen, which limits what a single mistaken or compromised manager session can do. Every creation, enabling and disabling is written to the audit trail.

3.4 Branding at sign-in and after sign-in

The Keycloak realm selects the KMC login theme, covering sign-in, required password change, errors and expired sign-in attempts. The signed-in shell carries the KMC lockup, department, system title, user and active role. The role remains visible because access differs materially by role, and a user must

be able to tell which authority is active without opening a menu. The final product name remains open at DEC-028, so the current QHSE Management System wording is an implementation position rather than an approved name.

4 Data

4.1 Ownership rules

Table 4.1: Data ownership rules

S/N	Rule	Statement
1	One database per stateful service	Identity, clinical, admin, occupational and metrics each read and write their own database and no other
2	Clinical separation	The clinical database is a separate instance with separate credentials and a separate encryption key
3	No cross context join	A reference across a context boundary is an identifier with no foreign key. Integrity across boundaries is an application concern
4	Soft deletion	A record that has been referenced is marked deleted rather than removed
5	Versioned change	Schema change is applied through numbered migration files held in source control and applied at startup
6	Clinical access log	The clinical service writes the log before returning a record. The table is in the clinical database and its service role is not prevented from updating or deleting rows

4.2 The clinical schema

The clinical context holds patients, visits, the state and content of visit sections, laboratory requisitions and requested investigations, referrals and authorisations, the referral leave outbox, and the clinical access log. They remain together because every one is an individual clinical record or a narrow fact derived from one under the same transaction boundary.

Section state is stored alongside section content rather than inferred from whether content exists. That is what allows the record to distinguish a section nobody has touched from one the officer decided does not apply, which is the distinction that makes a partially completed record auditable.

Vital signs are held as a document rather than as columns. The set is stable but sparsely populated, because a minor complaint records none of it, and twelve mostly empty columns model that worse than one document does.

The access log is not append-only against the database role used by the clinical service. The code has no update or delete operation for it, but no grant prevents that role issuing one and there is no separate hwms-audit deployable. The intended audit boundary therefore remains a production requirement rather than a delivered architectural property.

4.3 Snapshots on forms

A laboratory requisition and a referral each carry a snapshot of the patient information printed on them, taken when the form was raised. A later correction to the registry does not rewrite a form that has

already gone to the laboratory or to a receiving facility. The printed sheet and the stored record continue to agree.

4.4 Effective-dated reference data and frozen evaluations

The admin service holds KPI targets and industrial hygiene limits with an effective start date, an optional end date, a source and an approval state. Superseding a value closes the row in force and creates a replacement from a later date. Historical values remain available because changing a threshold is a business decision and must not silently rewrite earlier performance.

A hygiene reading asks admin for the limit in force on the reading date. Occupational copies the reference identifier, value, unit, averaging period, monitoring context, standard family and standard version onto the reading, then writes the compliance result. A database trigger refuses later changes to the measurement, the copied reference data or the result. This makes a past evaluation independent of any later limit revision.

5 Deployment

5.1 Environments

Three environments are defined. A local environment brought up by one command on a developer machine, a user testing environment on KMC controlled infrastructure holding synthetic data only, and a production environment that has not been requested and is not covered by this document.

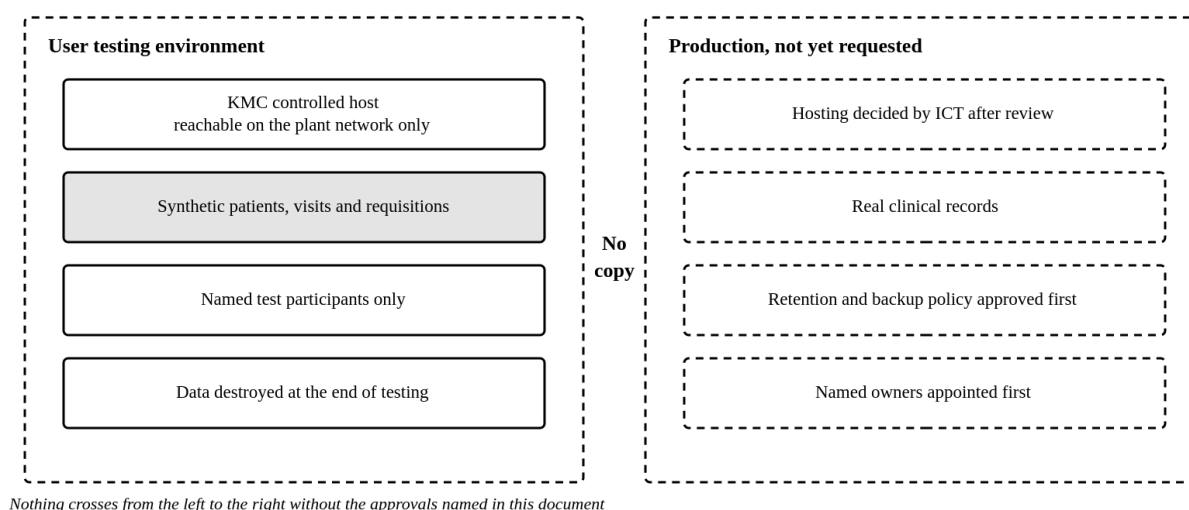


Figure 5.1: Separation Between User Testing and Production

The separation in Figure 5.1 is a requirement rather than a convention. No real clinical record is copied into a testing environment at any point.

5.2 Production Considerations

Table 5.1: Deployment constraints for production

S/N	Constraint	Detail
1	Gateway replicas	The gateway runs as a single replica until its session store is shared. Two

S/N	Constraint	Detail
		replicas would not share sessions and users would appear to be signed out at random
2	Secrets	No credential is held in the repository. Values are supplied by ICT from a controlled source. Development defaults must never reach a cluster
3	Clinical database isolation	A network policy permits only the clinical service to open a connection to the clinical database, so that even a leaked credential is not reachable
4	Transport	Encryption terminates at the ingress and session cookies are marked secure. The clinical database URL requires TLS, but the clinical StatefulSet configures no server certificate, so that connection cannot start as written
5	Backups	Nightly encrypted backup with the clinical backup under a separate key, and a restore tested quarterly
6	Orchestration	Kubernetes manifests define all six services, web, Keycloak and both database instances. ICT has not approved k3s rather than another arrangement

5.3 Observability

Each service exposes operational metrics which Prometheus collects and Grafana presents. Route templates are used as metric labels, so one address serves as one series rather than one per patient. That is a privacy rule and a practical one at the same time, since identifiers as labels would also make the metrics database unusable.

Ordinary request logs and panic recovery also record the chi route template rather than the concrete path. A patient, visit or referral identifier in a concrete URL would otherwise become clinical data in an operational log, where the clinical access controls do not apply. Query strings and bodies are not logged.

No clinical narrative reaches a log line, metric label or trace. Grafana is for operating the system and is not a second route to divisional data. No dashboard there queries clinical data and none reproduces an indicator.

6 Maintainability

A service per context is only maintainable by a small team if the cost of an additional service is close to zero. Six measures keep it there and none of them is optional.

Table 6.1: Measures that keep the topology maintainable

S/N	Measure	Detail
1	One repository	All services, the interface, the deployment manifests and the migrations sit together. A change spanning services is one commit and one review
2	One shared library	Configuration, logging, health, metrics, database access, migrations and token validation are written once and imported
3	One service skeleton	A new service is the skeleton plus its domain code. A service that reimplements the shared library has diverged
4	One pipeline	The same build and test path serves every service
5	One local command	The whole system starts on a laptop with a single command, so a new joiner is productive the same day

S/N	Measure	Detail
6	One test that blocks merges	The clinical access suite runs on every build and fails the build if any role other than the officer reaches a clinical route

6.1 Known limitations

Table 6.2: Known limitations and their consequences

S/N	Limitation	Consequence	Resolution
1	Session state is held in the gateway process	One replica only. A restart signs everybody out	Move the session store behind the existing interface to a shared store
2	Development secrets are in the repository	Acceptable on a laptop, unacceptable anywhere else	Supplied by ICT from a controlled source before any deployment
3	No continuous integration pipeline	Nothing enforces the build and tests on merge	Configure once a KMC source control remote exists
4	Logs and traces are not aggregated	Diagnosis requires reading each service in turn	Add log and trace collection alongside the existing metrics
5	Amendment of a signed visit is not implemented	A signed visit can be read but not corrected	Build the appended amendment before real records are entered
6	No separate audit service or restrictive access-log grants	The clinical service role can alter or delete its own access rows	Build hwms-audit and enforce insert-only grants
7	Clinical to metrics authentication uses a shared secret	The internal caller has no scoped service identity	Replace it with a Keycloak service account before production
8	Patient history export is generated in the browser	The download has no distinct audit event or versioned server template	Resolve DEC-037 and move controlled generation server side if archival reproduction remains required
9	Clinical database TLS is incomplete in k3s	The connection URL requires TLS but the StatefulSet supplies no server certificate	ICT supplies certificates and server configuration, or approves a different written connection policy

7 Handover

The system was built during a student attachment that is ending. The following is recorded so that the work can be continued by another party.

Table 7.1: Position at handover

S/N	Item	Position
1	Built and working	KMC sign-in theme, roles, account administration, clinical records and forms, referrals, ergonomics, industrial hygiene, monthly returns with corrections, effective-dated reference APIs and the nine-indicator dashboard
2	Specified and not built	Signed visit amendments, the separate audit deployable, controlled server-side document templates, report archive, log aggregation and continuous integration
3	Highest priority next step	Resolve the production blockers in the stakeholder register, then close audit isolation, export auditing and the clinical database TLS mismatch
4	Principal design risk	Erosion of the clinical access rule under management pressure. It is recorded with its reasoning so that any change is made deliberately and by an authorised party
5	Principal delivery risk	No named owner after the attachment ends. This is a release blocker rather than a preference

S/N	Item	Position
6	Where the truth lives	The supplied forms and the divisional dashboard are the primary sources. Everything else is derived from them or marked as a proposal

Table 7.2: Architecture document sign-off

Role	Name	Signature	Date
Prepared by, Software Engineering Intern			
Reviewed by, KMC ICT			
Approved by, Head of Department, Quality, Health, Safety and Environment			